

TAREA PPS04

Defensas anti-ingeniería inversa y soluciones CASB

Autor: Carlos España Del Pozo - CETI

Contenido

Detalles de la tarea de esta unidad	3
Apartado 1: MASTG	3
Apartado 2: MDM y CASB	5
Apartado 3: Diseño y capacidades de CASB.....	7

Detalles de la tarea de esta unidad

Caso práctico

Julián ha estado trabajando en un proyecto de una aplicación móvil junto con una solución CASB que quiere salir al mercado y ser revolucionaria.

Para comprobar que la aplicación es segura se ha seguido la última versión de la Guía de Pruebas de Seguridad de Aplicaciones Móviles (MASTG) desarrollada por OWASP. Julián entiende que el Estándar de Verificación de Seguridad de Aplicaciones Móviles (MASVS) proporciona un marco claro y detallado que aborda los requisitos de seguridad esenciales para el desarrollo y la evaluación de aplicaciones móviles. Por otro lado, la Guía de Pruebas de Seguridad de Aplicaciones Móviles (MASTG) se alinea estrechamente con los requisitos establecidos por la MASVS, ofreciendo un conjunto adicional de directrices específicas para realizar pruebas de seguridad efectivas en aplicaciones móviles. La combinación de ambas herramientas, MASVS y MASTG, proporciona un enfoque integral para evaluar y mejorar la seguridad en aplicaciones móviles, permitiendo a los profesionales adaptar sus estrategias según el contexto específico.

Uno de los puntos que más se han trabajado durante el proyecto de la solución CASB es ser diferenciadores y poder corregir los problemas de adopción que han tenido las soluciones de MDM (Mobile Device Management). Saben que las soluciones para móviles tienen que ser capaces de lidiar con varios problemas como la privacidad, BYOD (Bring Your Own Device), etc.

Esta tarea es eminentemente teórica donde el alumno deberá responder y desarrollar una serie de preguntas. El alumno debe saber manejar guías para comprobar si una aplicación móvil es segura o no, entender distintos conceptos como CASB, MDM, BYOD, etc y ser capaz de entender que capacidades aportan las soluciones tecnológicas, con qué problemas se encuentran en el mercado y qué capacidades adicionales podrían tener y qué las empresas valorarían.

Apartado 1: MASTG

En la unidad 2 ya vimos que OWASP ha desarrollado el proyecto Mobile Application Security (MAS) que proporciona un estándar de seguridad para aplicaciones móviles (OWASP MASVS) y una guía de pruebas exhaustiva (OWASP MASTG) que cubre los procesos, técnicas y herramientas utilizados durante una prueba de seguridad de aplicaciones móviles, así como un conjunto exhaustivo de casos de prueba que permite a los probadores ofrecer resultados coherentes y completos.

En este apartado se pide revisar la guía MASTG, centrándote en las diferentes defensas contra la Ingeniería Inversa en Android (Android Anti-Reversing Defenses) y en iOS (iOS Anti-Reversing Defenses)

- Una medida defensiva es **comprobar el "Rooteado" en Android y el "Jailbreak" en iOS**. Rellena la siguiente tabla utilizando la guía MASTG

¿Qué son los dispositivos rooteados o con jailbreak?	Los dispositivos rooteados (Android) o con Jailbreak (iOS) son dispositivos que han sido modificados a nivel de software para modificar restricciones del sistema operativo y escalar privilegios a root.
--	---

Indica 1 medida para comprobar el rooteado	Tal como indica la guía en: MASTG-TECH-0144 : Bypassing Root Detection: La aplicación puede verificar la existencia de binarios de superusuario como “su” o “magisk” en rutas comunes (ej. /system/bin/su).
Indica 1 medida para comprobar el Jailbreak	Tal como indica la guía en: MASTG-KNOW-0084 : Jailbreak Detection: Ver llamadas a protocolos conocidos como cydia://

2. Otra medida defensiva es la **ofuscación**. Rellena la siguiente tabla utilizando la guía MASTG

¿En qué consiste la ofuscación?	Como vemos en: MASTG-KNOW-0033: Obfuscation: Técnica que transforma el código para hacerlo difícil de entender, analizar o modificar, sin cambiar su funcionalidad.
Indica para que se utiliza la herramienta ProGuard y cómo se utiliza	En las aplicaciones Android se utiliza la herramienta ProGuard para realizar labores de ofuscación. Funciona reemplazando identificadores (clases, métodos, variables) por cadenas sin sentido
Indica para que se utiliza la herramienta SwiftShield y cómo se utiliza	En las aplicaciones iOS se utiliza la herramienta SwiftShield para generar nombres cifrados para los objetos de un proyecto. Se descarga el ejecutable, se copia a /usr/local/bin y se ejecuta el comando swiftshield en el directorio del proyecto

3. Explorar aplicaciones utilizando un depurador es una técnica muy poderosa. No solo se puede rastrear variables que contienen datos confidenciales y modificar el flujo de control de la aplicación, sino también leer y modificar la memoria y los registros. Rellena la siguiente tabla utilizando la guía MASTG

Explica qué consiste la técnica antidepuración JDWP en Android	Consiste en que la aplicación detecta si se está ejecutando en modo depurable y reacciona cerrándose
Explica qué es ptrace y cómo se puede utilizar para evitar la depuración en IOS	Consiste en una llamada al sistema del kernel XNU de iOS. Se utiliza para evitar la depuración mediante el comando PT_DENY_ATTACH, que asegura que ningún otro depurador pueda acoplarse al proceso; si un depurador lo intenta, el proceso se termina automáticamente.

4. La presencia de herramientas, frameworks y aplicaciones comúnmente utilizadas por la ingeniería inversa puede indicar un intento de realizar ingeniería inversa en la aplicación. Algunas de estas herramientas sólo pueden ejecutarse en un dispositivo con jailbreak o rooteado, mientras que otras obligan a la aplicación a entrar en modo de depuración o dependen del inicio de un servicio en segundo plano en el teléfono móvil. Por lo tanto, **existen diferentes formas que una aplicación puede implementar para detectar un ataque de ingeniería inversa y reaccionar ante él**, por ejemplo, finalizándose ella misma. Utilizando la guía MASTG

Explica qué es y para que se utiliza la herramienta Frida	Es un framework de dinámico que permite realizar hooking de funciones en tiempo de ejecución. Se utiliza para inyectar scripts, modificar variables y evadir controles de seguridad (como las detecciones de root) mientras la aplicación se ejecuta.
Explica cómo se puede detectar en IOS (Frida Detection)	En iOS, se puede detectar realizando comprobaciones en el sistema de archivos para buscar componentes específicos de la herramienta, como la presencia del binario /usr/sbin/frida-server o librerías como libcrypt.dylib.

Apartado 2: MDM y CASB

Los servicios **CASB (Cloud Access Security Broker)** y las plataformas **MDM (Mobile Device Management)** desempeñan roles esenciales en la seguridad de la información en entornos empresariales modernos. La combinación de CASB y MDM proporciona un enfoque integral para abordar las amenazas modernas, asegurando tanto los datos en la nube como los dispositivos móviles, lo que es crucial para salvaguardar la integridad y confidencialidad de la información empresarial.

1. Rellena la siguiente tabla comparativa CASB vs MDM

	CASB	MDM
Objetivo principal	Protege el acceso a recursos en la nube (SaaS, PaaS, IaaS) de una organización.	Gestionar y revisar de forma centralizada, dispositivos móviles (smartphones, portátiles) dentro de la organización.
Alcance y enfoque	El alcance sería la Nube y las aplicaciones que corren en esta.	El alcance sería los dispositivos móviles y las aplicaciones de estos de una organización.
Gestión (¿qué elementos se gestionan?)	Identidad, usuarios, accesos a servicios y aplicaciones.	Dispositivos físicos y aplicaciones de estos.
Arquitectura (¿cómo se implementa?)	Mediante proxy o integración API.	Mediante aplicaciones centralizadas y clientes en los dispositivos.
¿Qué problemas o limitaciones tiene cada uno (por ejemplo, con la protección de datos)?	Dependencias del proveedor del cloud, no protege dispositivos.	Rechazo en entornos BYOD por temas de privacidad. Solo es útil si los dispositivos de acceso están gestionados por MDM.
Da 3 ejemplos de soluciones MDM y 3 CASB	Microsoft Defender for Cloud Apps Netskope McAfee MVISION Cloud	Microsoft Intune Jamf Pro VMware Workspace ONE

A la hora de escoger una solución CASB es importante conocer cuáles son las características más importantes de las mismas.

2. Rellena la siguiente tabla, identificando y describiendo detalladamente y con un ejemplo al menos cinco características clave que suelen ofrecer las soluciones CASB (ejemplo: control de acceso, prevención de fuga de datos, etc.). Como ejemplo de lo que se pide se rellena una característica típica como el control de acceso

Característica	Descripción detallada	Ejemplo
Control de acceso y autenticación	Implementa políticas de acceso basadas en el contexto, como ubicación, tipo de dispositivo, nivel de riesgo o autenticación multifactor (MFA). Se puede restringir el acceso en función del usuario o del rol dentro de la empresa.	Un usuario intenta acceder a la aplicación de contabilidad desde un dispositivo no administrado. El CASB impide el acceso o solicita autenticación adicional.
Prevención de fuga de datos (DLP)	Analiza el contenido que se sube o descarga en aplicaciones cloud para detectar información sensible.	Un empleado intenta subir una base de datos con números de tarjetas de crédito a Microsoft Drive. El CASB detecta el patrón y bloquea la subida.
Protección contra amenazas (Threat Protection)	Incorpora análisis de comportamiento (UEBA), detección de anomalías en servicios cloud	Se detecta un inicio de sesión desde un país inusual y descarga masiva de archivos en pocos minutos. El CASB bloquea la sesión
Cifrado de datos	Permite cifrar datos sensibles antes de almacenarlos en la nube	Los datos personales de clientes almacenados en un CRM se cifran antes de enviarse al servicio
Visibilidad de Shadow IT	Identifica aplicaciones en la nube no autorizadas por el departamento de TI	El CASB detecta que varios empleados usan cuentas personales de Dropbox para mover archivos corporativos sin permiso
Control de cumplimiento normativo	Ayuda a cumplir regulaciones como RGPD, NIS2 o PCI-DSS mediante auditorías, informes y aplicación de políticas	La empresa genera un informe automático que demuestra que los datos personales están protegidos

Apartado 3: Diseño y capacidades de CASB

Elige una solución CASB disponible en el mercado (ejemplo: Microsoft Defender for Cloud Apps, Netskope, McAfee MVISION Cloud, Palo Alto Prisma Access, etc.).

1. Rellena la siguiente tabla describiendo cinco características de dicha solución que te han parecido las más importantes (deben ser distintas a las que has puesto en el apartado 2.2). Justifica por qué te parecen importantes.

Microsoft Defender for Cloud Apps

Característica	Justificación
Integración nativa con Microsoft 365 y Azure AD	Permite aplicar políticas de seguridad directamente vinculadas a identidades corporativas, grupos y roles en entornos Microsoft.
Gobernanza de Aplicaciones (OAuth)	Supervisa y controla las aplicaciones de terceros que acceden a los datos mediante tokens OAuth
Integración con Tags	Aplica protección y cifrado automáticamente a archivos basados en su contenido (ej. etiquetas de "confidential"). Garantiza que el almacenamiento de datos sensibles sea seguro incluso fuera de la nube corporativa
Monitoreización mediante API Cloud-to-Cloud	Permite supervisar el movimiento de datos entre nubes (ej. de MS Drive a Dropbox) sin necesidad de agentes en el dispositivo.
Integración con Microsoft Defender XDR y Sentinel (SIEM/SOAR)	Permite correlacionar eventos cloud con endpoints y correo electrónico, proporcionando una visión holística de amenazas.

2. Responde a las siguientes cuestiones:

¿Qué problema supone cuando un usuario se va de la empresa en un entorno de BYOD (Bring Your Own Device)?

¿Qué mecanismos deberías tener en la solución CASB que has planteado en el apartado 3.1 para cuando un usuario abandone la compañía y siga siendo compatible con BYOD?

En este apartado tenemos problemas complejos de solventar y que en el actual paradigma tecnológico y de evolución digital en el que nos encontramos, se han implementado diversas medidas para evitar, sobre todo, fugas de información y datos de carácter personal.

Los problemas más relevantes son:

- Un usuario puede conservar datos corporativos descargados en su dispositivo personal.

- Puede conservar acceso a correos o documentos sincronizados offline.
- Puede tener tokens de autenticación válidos.
- Existen conflictos legales y de privacidad: la empresa no puede borrar todo el dispositivo porque es personal.

Los mecanismos que se tienen que activar en las soluciones CASB pueden ser:

- Revocación de permisos
- Forzar cierres de sesión en todos los aplicativos y dispositivos vinculados al usuario.
- Restricción de descargas offline en dispositivos no gestionados.